

راهنمای کاربر مرکز فرماندهی AO-SOC

نویسنده	J.Ekrami
هم‌نویسنده	Claude (Opus 5)
حق نشر	J.Ekrami-Labs ©
تاریخ	تابستان ۱۴۰۵
نسخه سند	۲/۰
برای	ao-soc نسخه ۲/۸/۱۱

این راهنما برای کسانی نوشته شده که با AO-SOC کار می‌کنند: تحلیل‌گر شیف، سرپرست شیف و کسی که سامانه را نصب و نگهداری می‌کند. هدفش یک چیز است؛ اینکه بعد از خواندنش بتوانید یک رخداد را از لحظه‌ای که در صف ظاهر می‌شود تا وقتی در بایگانی بسته می‌شود، درست پیش ببرید.

برای معماری، APIها و جزئیات پیکربندی به [README.md](#)، [orchestrator/README.md](#) و برنامه مرحله به مرحله راه‌اندازی در [docs/PILOT-RUNBOOK.md](#) مراجعه کنید.

دربارۀ تصویرها: همه از محیط نمایشی (بخش ۲/۱) و از رابط فارسی گرفته شده‌اند. برچسب‌ها، منوها و دکمه‌ها فارسی‌اند، اما عنوان رخدادها و متن استدلال مدل به همان زبانی است که از ابزار تشخیص و از مدل بیرون می‌آید، یعنی انگلیسی. در سامانه واقعی شما هم همین‌طور خواهد بود.

۱. AO-SOC چه می‌کند و چه نمی‌کند
۲. نصب
۳. ورود به سامانه
۴. چیدمان صفحه و نوار بالا
۵. مرکز فرماندهی
۶. کار روی یک رخداد: تصمیم سطح ۲
۷. هشدارهای زنده و راهنمای رخداد
۸. فهرست رخدادها و صفحه جزئیات
۹. بایگانی و بازگردانی اقدام‌ها
۱۰. ریسک موجودیت‌ها
۱۱. سلامت سامانه
۱۲. تغییر زبان
۱۳. روال یک شیفت
۱۴. واژه‌نامه نشان‌ها و وضعیت‌ها
۱۵. وقتی چیزی درست کار نمی‌کند

۱. AO-SOC چه می‌کند و چه نمی‌کند

مسئله‌ای که AO-SOC حل می‌کند این است: ابزارهای تشخیص هر کدام بخشی از یک حمله را می‌بینند و هیچ‌کدام کل آن را نمی‌بینند. اسپلانک تلاش ناموفق برای ورود را گزارش می‌کند، Wazuh ارتقای دسترسی روی همان میزبان را، و فایروال یک اتصال خروجی مشکوک را. سه هشدار جدا روی میز تحلیل‌گر می‌آید و کسی باید بفهمد که این سه، یک ماجراست.

AO-SOC **لایهٔ تصمیم‌گیری** است، نه ابزار تشخیص. لاگ جمع نمی‌کند، لاگ نگه نمی‌دارد و خودش حمله را کشف نمی‌کند. کار آن روی چیزی شروع می‌شود که ابزارهای موجود (Splunk، Wazuh، Elastic، Sentinel، CrowdStrike یا هر ابزاری که CEF می‌فرستد) برایش می‌فرستند:

۱. **همبسته‌سازی.** تشخیص‌هایی که در یک بازهٔ زمانی به یک کاربر، میزبان یا نشانی مربوط‌اند، در یک **وضعیت امنیتی** واحد جمع می‌شوند. سه هشدار بالا یک رخداد می‌شود، نه سه رخداد.

۲. **پیشنهاد تصمیم.** یک مدل زبانی محلی که روی Ollama و کاملاً درون سازمان اجرا می‌شود، وضعیت را می‌خواند و یک **تصمیم سطح ۲** پیشنهاد می‌دهد: **CONTAIN**، **ESCALATE**، **INVESTIGATE**، **MONITOR** یا **IGNORE**.

همراه تصمیم، یک **برنامهٔ اقدام** هم می‌آید؛ مثلاً مسدودکردن یک نشانی یا قرنطینهٔ یک میزبان.

۳. **پرسیدن از انسان.** برنامه یک‌بار جلوی تحلیل‌گر می‌آید و او آن را تأیید، اصلاح یا رد می‌کند.

۴. **اجرا و ثبت.** اقدام‌های تأییدشده به ابزارهای پاسخ (SOAR، EDR، فایروال، سامانهٔ هویت) فرستاده می‌شوند، هر گام در ردپای حسابرسی ثبت می‌شود و اقدامی که وارونه دارد، از همین داشبورد قابل بازگردانی است.

```
Detection tools → AO-SOC correlation → AI Tier-2 decision → analyst (approve / edit / reject)
→ policy guardrails → response tools → audit, archive, rollback
```

نکته دربارهٔ واژهٔ «راهنما» (Playbook). در AO-SOC راهنما چیزی نیست که دستی بنویسید. راهنما همان برنامهٔ اقدامی است که به هر تصمیم پیوست می‌شود و در دو جا دیده می‌شود: **برنامه اقدام یکپارچه** در پنل تصمیم سطح ۲ که تأیید و اجرا می‌شود، و فهرست **راهنمای رخداد** در صفحهٔ هشدارهای زنده که فقط خلاصهٔ مراحل مهار است و دکمهٔ اجرا ندارد.

۲. نصب

دو راه برای اجرای AO-SOC وجود دارد و انتخاب میانشان به این بستگی دارد که می‌خواهید سامانه را ببینید یا از آن استفاده کنید.

بخش	مناسب	
۲/۱	آشنایی، آموزش تحلیل‌گر تازه‌وارد، ضبط ویدیو. با هشدارهای نمونه کار می‌کند و به مدل نیاز ندارد	حالت نمایشی
۲/۲	آزمایش میدانی یا استقرار واقعی، با تشخیص‌های واقعی سازمان	حالت عملیاتی (Docker)

۲/۰ پیش‌نیازها

جزء	نسخه	برای چه لازم است
Python	۳/۱۱ یا بالاتر	اجرای کارگزار در حالت نمایشی
npm و Node.js	۲۰ یا بالاتر	اجرای API رابط کاربری و داشبورد در حالت نمایشی
Docker و Docker Compose	نسخه جدید	حالت عملیاتی
Ollama با مدل qwen3.5:latest یا qwen2.5:7b	اختیاری	تصمیم واقعی مدل. بدون مدل، سامانه در حالت بدون مدل کار می‌کند و تصمیم را یک قاعده مبتنی بر شدت می‌گیرد
مرورگر	Edge، Chrome یا Firefox به‌روز	داشبورد برای نمایشگر ۱۰۸۰×۱۹۲۰ و بزرگ‌تر طراحی شده و روی تبلت و گوشی هم باز می‌شود

درگاه‌هایی که سرویس‌ها روی آن گوش می‌دهند:

سرویس	درگاه	توضیح
کارگزار، موتور تصمیم	8500	تشخیص‌ها را از ابزارها می‌گیرد
API رابط کاربری	4317	داده‌های داشبورد را می‌رساند
داشبورد در حالت نمایشی	5173	http://localhost:5173
داشبورد در حالت عملیاتی	8080	تنها درگاهی که Docker بیرون می‌دهد؛ با DASHBOARD_PORT قابل تغییر است

۲/۱ نصب نمایشی روی ویندوز، لینوکس و macOS

کد را بگیرید و در پوشه `ao-soc` یک ترمینال باز کنید. بعد یک فرمان، کل پشته را بالا می‌آورد. ویندوز، در PowerShell:

```
.\scripts\start-demo.ps1
```

```
chmod +x scripts/start-demo.sh scripts/stop-demo.sh
./scripts/start-demo.sh
```

اسکرپت نصب بودن Python و Node را بررسی می‌کند، وابستگی‌ها را نصب می‌کند (در اجراهای بعدی با `-SkipInstall` یا `--skip-install` از این مرحله بگذرید)، سه سرویس را هرکدام در یک پنجره جدا بالا می‌آورد، **۱۲ هشدار نمونه** بار می‌کند (یکی از آن‌ها وضعیتی است که از سه ابزار همبسته شده) و در پایان کلید ورود را چاپ می‌کند:

Sign in at the dashboard with this operator key:

Xy7...your-key...Qp

این کلید را کپی کنید؛ برای ورود به داشبورد لازم می‌دارید. سپس نشانی `http://localhost:5173` را باز کنید. حالت نمایشی سه صورت دارد:

فرمان (ویندوز / لینوکس)	چه اتفاقی می‌افتد
<code>start-demo.sh / start-demo.ps1</code>	هر ۱۲ هشدار یک‌جا بار می‌شود
<code>start-demo.sh --live / start-demo.ps1 -Live</code>	هشدارها در حدود دو دقیقه یکی‌یکی می‌رسند و پرشدن صف را زنده می‌بینید
<code>start-demo.sh / start-demo.ps1 -Ai -Count 6 --ai --count 6</code>	مدل محلی Ollama واقعاً هر هشدار را تحلیل می‌کند؛ برای هر هشدار ۱۰ تا ۴۰ ثانیه وقت بگذارید

توقف همه سرویس‌ها:

```
.\scripts\stop-demo.ps1
```

```
./scripts/stop-demo.sh
```

هشدار. هر بار که حالت نمایشی را اجرا می‌کنید، هشدارهای نمایشی پیشین پاک و از نو ساخته می‌شوند. اسکرپت‌های نمایشی را هرگز روی پایگاه داده عملیاتی اجرا نکنید.

۲/۲ نصب عملیاتی با Docker

استقرار عملیاتی مرحله به مرحله در docs/PILOT-RUNBOOK.md آمده و ترتیب مرحله‌ها اهمیت دارد. خلاصه کار این است:

گام ۱. فایل تنظیمات را از روی نمونه بسازید.

```
cp deploy/.env.example deploy/.env
```

گام ۲. برای هر شخص و هر سامانه یک کلید جدا بسازید. این فرمان را به تعداد کلیدها تکرار کنید:

```
python -c "import secrets; print(secrets.token_urlsafe(32))"
```

کلیدها در `deploy/.env` به این شکل نوشته می‌شوند:

تنظیم	دارنده کلید	نمونه
BROKER_API_KEYS	سامانه‌ها؛ SIEM با نقش ingest و API رابط کاربری با نقش service	ui-api:service:<key>,siem:ingest:<key>
UI_API_BROKER_KEY	API رابط کاربری، همان رمز مدخل service بالا	<key>
AOSOC_API_KEYS	هر تحلیل‌گر، به صورت شخصی، برای ورود به داشبورد	soclead:analyst:<key>,dutydesk:viewer:<key>

قالب هر مدخل `name:role:secret` است و مدخل‌ها با ویرگول لاتین از هم جدا می‌شوند.

به هر تحلیل‌گر کلید خودش را بدهید. تأیید، ویرایش و بازگردانی به نام صاحب کلید ثبت می‌شود؛ با کلید مشترک، ردپای حسابرسی نام هیچ‌کس را نشان نمی‌دهد و همین یک قلم، کل سازوکار پاسخ‌گویی را بی‌اثر می‌کند.

گام ۳. اول تنظیمات را بررسی و بعد سرویس‌ها را اجرا کنید:

```
python deploy/check_env.py
```

```
docker compose --env-file deploy/.env -f deploy/docker-compose.yml up -d
```

`check_env.py` موردی را گزارش می‌کند که در پوسته شما مانده و بی‌صدا روی `deploy/.env` را می‌پوشاند؛ مثلاً متغیری که از یک اجرای نمایشی باقی مانده است.

گام ۴. داشبورد را روی `http://<server>:8080` باز کنید و با کلید تحلیل‌گر خود وارد شوید.

گام ۵. ابزارهای تشخیص را به کارگزار وصل کنید. اسپلنک به `POST http://<broker-host>:8500/splunk-alert` می‌فرستد و بقیه ابزارها به `POST http://<broker-host>:8500/detections`. هر درخواست باید کلید `ingest` را در سرآیند `X-API-Key` داشته باشد؛ تشخیصی که بدون کلید برسد پذیرفته نمی‌شود.

محدودیت عمدی در نصب تازه. پیکربندی پیش فرض با `LLM_PROVIDER=echo` (بدون مدل)، `TIER2_AUTOPILOT=false` (تصمیم‌ها منتظر انسان می‌مانند) و `RESPONSE_DRY_RUN=true` (چیزی به هیچ ابزار واقعی فرستاده نمی‌شود) بالا می‌آید. این‌ها را یکی یکی و به ترتیبی که در برنامهٔ راه‌اندازی آمده فعال کنید، نه همه را با هم.

۲/۳ نقش‌ها

نقش	چه کاری از او برمی‌آید
viewer	همه چیز را می‌بیند. تأیید، ویرایش، رد و بازگردانی برایش بسته است
analyst	می‌بیند و اقدام می‌کند: تأیید، ویرایش، رد، ثبت نتیجه، بازگردانی و کار روی پرونده
ingest	نقش سامانه‌ای؛ فقط تشخیص می‌فرستد
service	نقش سامانه‌ای؛ API رابط کاربری که از طرف تحلیل‌گر وارد شده عمل می‌کند
admin	همه چیز. به طور پیش فرض به کسی داده نمی‌شود

ورود به AO-SOC

این کنسول می‌تواند اقدام‌هایی را تأیید کند که روی شبکه اجرا می‌شوند.
هر درخواست احراز هویت می‌شود.

کلید API کاربر

.....

ورود

کلید فقط در همین زبانه مرورگر نگهداری می‌شود و با بستن زبانه پاک می‌گردد.

نشانی داشبورد را باز کنید، کلید API خود را در کادر بگذارید و **ورود** را بزنید.

کلید فقط در همین زبانه مرورگر می‌ماند. با بستن زبانه از سامانه خارج می‌شوید و این عمدی است: روی رایانه مشترک مرکز عملیات، نشست شما نباید به شیفت بعد برسد. اگر کلید نادرست یا باطل باشد، همین صفحه دوباره می‌آید.

۴. چیدمان صفحه و نوار بالا



نوار بالا در همهٔ صفحه‌ها یکی است و در رابط فارسی از راست به چپ چیده می‌شود.



شماره	بخش	کارکرد
۱	نشان AO-SOC	بازگشت به مرکز فرماندهی
۲	منوی اصلی	شش صفحهٔ سامانه
۳	وضعیت خط لوله	چهار نقطه برای اسپلنک، کارگزار هوش مصنوعی، مدل زبانی و پاسخ خودکار. سبز یعنی آنلاین، کهربایی یعنی تضعیف‌شده، قرمز یعنی آفلاین و خاکستری یعنی هنوز پاسخی نرسیده. هر ۵ ثانیه به‌روز می‌شود
۴	وضعیت امنیتی	وضعیت کلی سازمان با امتیاز ۰ تا ۱۰۰: پایین، محافظت‌شده، افزایش‌یافته یا بالا
۵	EN / FA	تغییر زبان رابط
	ساعت	ساعت و تاریخ محلی، در رابط فارسی با تقویم خورشیدی

شش صفحهٔ منو و کاری که هرکدام به آن می‌آید:

گزینهٔ منو	نشانی	کی سراغش می‌روید
مرکز فرماندهی	/	صفحهٔ کار روزمره؛ همه‌چیز یک‌جا و امکان کار روی رخداد

گزینهٔ منو	نشانی	کی سرآغش می‌روید
هشدارهای زنده	/alerts	مرور سریع گزارش خام هشدارها و دیدن راهنمای مهار هر هشدار
رخدادها	/incidents	فهرست کامل رخدادهای فعال و باز کردن یکی از آن‌ها با جزئیات
بایگانی	/archive	مرور رخدادهای بسته‌شده: چه تصمیمی گرفته شد، چه کسی تأیید کرد و چه اجرا شد
ریسک موجودیت‌ها	/entities	دیدن پرریسک‌ترین کاربران، میزبان‌ها و نشانی‌ها
سلامت سامانه	/health	بررسی زنده‌بودن خط لوله و داده‌های پایش

در پانویس هر صفحه، نسخهٔ برنامه (مثلاً v2.8.11) نوشته شده است. هنگام گزارش اشکال همین شماره را بنویسید.

۵. مرکز فرماندهی

این صفحه شش ردیف دارد و از بالا به پایین به ترتیب جواب می‌دهد: الان چه چیزی توجه می‌خواهد، چقدر جدی است، مدل چرا چنین می‌گوید، چه باید کرد و وضعیت کلی کجاست.

۵/۱ خلاصه مدیریتی



نوار جریان کارگزار شمار رخدادهای زنده، رخدادهایی که منتظر تصمیم انسان‌اند و رخدادهای مهارشده را نشان می‌دهد. دکمهٔ **بروزرسانی هشدارها** بی‌درنگ داده را تازه می‌کند و صفحه هر ۱۵ ثانیه خودش هم این کار را انجام می‌دهد.

سه کارت بعدی به ترتیب وضعیت امنیتی و ترکیب شدت رخدادهای باز، زمان‌های پاسخ (MTTR و MTTD) و توزیع ریسک، و در آخر میانگین اطمینان مدل به همراه شمار رخدادهای بحرانی، پراولویت و همبسته را نشان می‌دهند.

دربارهٔ عدد اطمینان. این عدد گزارش خود مدل است و کالیبره نیست؛ مدل‌های محلی تقریباً برای هر ورودی عددی بین ۷۵ تا ۹۸ درصد می‌دهند. از آن برای مرتب‌کردن کار استفاده کنید، نه به‌عنوان دلیل تأیید یک برنامه.

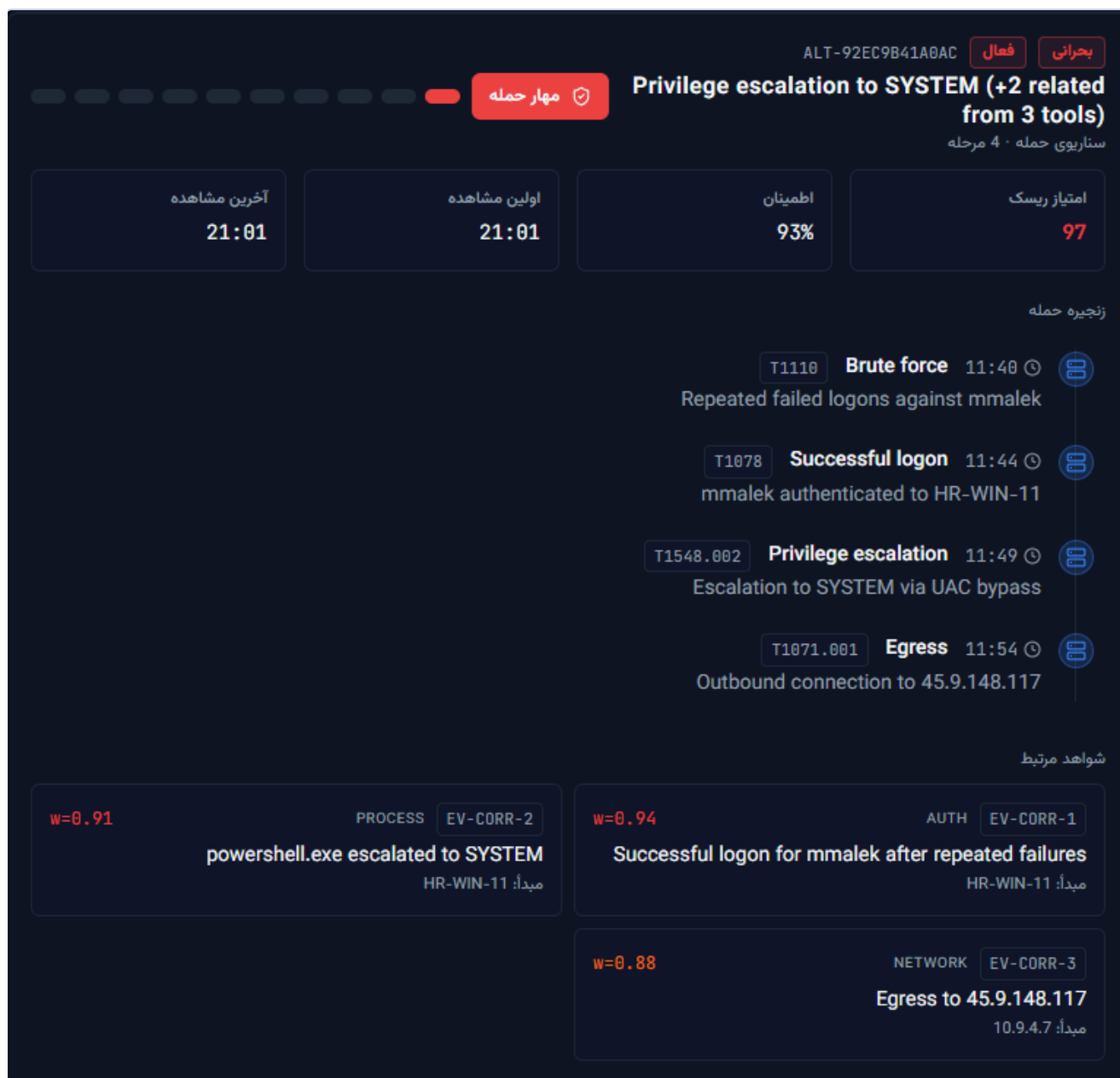
۵/۲ عملیات اصلی

کار اصلی تحلیل‌گر در این ردیف انجام می‌شود.

12 / 42

عنوانی مثل «*Privilege escalation to SYSTEM (+2 related from 3 tools)*» یعنی این رخداد از سه تشخیص در سه ابزار مختلف ساخته شده است.

سناریوی حمله



ردیف بالا امتیاز ریسک، اطمینان، اولین و آخرین مشاهده را می‌دهد. زیر آن، **زنجیره حمله** مرحله‌های حمله را به ترتیب زمان با شناسه تکنیک MITRE ATT&CK نشان می‌دهد و **شواهد مرتبط** تک‌تک شواهد را با نوع و وزنشان. دکمه قرمز **مهار حمله** رخداد را دستی «مهار شده» علامت می‌زند و هیچ اقدامی را اجرا نمی‌کند. فقط وقتی به کار می‌آید که تهدید بیرون از AO-SOC مهار شده باشد و بخواهید سابقه را با واقعیت هماهنگ کنید. مسیر عادی، تأیید برنامه در پنل تصمیم است (بخش ۶).

وضعیت امنیتی: چرا چند هشدار یک رخداد شدند



نکته درباره نام‌ها. عنوان این پنل و برچسب نوار بالا هر دو «وضعیت امنیتی» است، ولی دو چیز متفاوت‌اند: پنل درباره تشخیص‌هایی است که همین رخداد را ساخته‌اند و برچسب نوار بالا درباره وضعیت کلی سازمان. نشان‌های ابزار در بالای پنل می‌گویند کدام ابزارها این وضعیت را گزارش کرده‌اند و عبارت **تأیید مستقل از چند ابزار** یعنی بیش از یکی. **امتیاز ریسک همبستگی** سطر به سطر نوشته شده تا معلوم باشد هر امتیاز از کجا آمده: بیشترین شدت میان تشخیص‌ها، همبستگی میان ابزارها، شمار تشخیص‌ها و شمار تکنیک‌های متمایز. این عدد شمارش واقعیت‌هاست و نظر مدل در آن دخالتی ندارد.

همبسته بر اساس فهرست موجودیت‌های مشترکی است که تشخیص‌ها را به هم وصل کرده‌اند، و **تشخیص‌های عضو** خود تشخیص‌های اصلی. هر تشخیص را که باز کنید، موجودیت‌ها، تکنیک‌ها و پیوند بازگشت به ابزار مبدأ آن را می‌بینید.

راستی‌آزمایی و سابقه

چه چیزی در برابر یک مرجع بررسی شد و این مرکز عملیات پیش‌تر چه تصمیمی گرفته است

sample-data egress credential-theft sample-indicator-set 45.9.148.117 **MALICIOUS**

2 مورد بررسی نشد (نشانی‌های داخلی و هویت‌ها هرگز به فید فرستاده نمی‌شوند)

سابقه

سابقه به‌اندازه مشابهی وجود ندارد – این تصمیم به‌اقتضای طراحی منتظر تحلیل‌گر می‌ماند.

این پنل دو چیز را جدا نگه می‌دارد. اول، نشانه‌هایی که در برابر فید هوش تهدید بررسی شده‌اند: نشان **MALICIOUS** یعنی نشانه در فید آمده است. «بررسی شد و یافت نشد» به معنای بی‌خطر بودن نیست و «بررسی نشد» به نشانی‌های داخلی و هویت‌ها مربوط است که اصلاً به فید فرستاده نمی‌شوند. دوم، **سابقه**: اینکه همین مرکز عملیات در موارد مشابه پیش‌تر چه تصمیمی گرفته است.

اگر بخوانید «سابقه به‌اندازه مشابهی وجود ندارد»، یعنی رخداد تازه است و طراحی سامانه آن را به تحلیل‌گر می‌سپارد. پنل خالی هم نتیجه پاک نیست؛ اگر هیچ فید هوش تهدیدی پیکربندی نشده باشد، پنل همین را صریح می‌نویسد.

پرونده

پرونده

چه کسی روی آن کار می‌کند و در چه وضعیتی است

P1 تازه CASE-FCBC4A8B46

هنوز کسی مسئول این پرونده نیست

واگذاری به...

بازگرداندن به صف

واگذارشده در دست بررسی ارجاع‌شده حل‌شده بسته‌شده

ارجاع به سطح بالاتر

افزودن یادداشت به پرونده...

افزودن یادداشت

سامانه مرجع

هیچ سامانه تیکت‌نگی پیکربندی نشده است. این پرونده تنها همین‌جا نگهداری می‌شود – ناهماهنگ نیست، چیزی برای هماهنگ‌شدن وجود ندارد.

بازخوانی

سوابق پرونده

پرونده برای موقعیت SIT-9D042D292ED1 گشوده شد - 9/21/2026, 9:01:18 PM - ao-soc

پرونده جواب این پرسش است که چه کسی روی رخداد کار می‌کند و کار در چه وضعیتی است. شناسه، وضعیت و اولویت (P1 بالاترین) در بالای پنل می‌آید.

با کادر **واگذاری به...** نامی را می‌نویسید و **واگذاری** را می‌زنید؛ **بازگرداندن به صف** مسئول را برمی‌دارد. دکمه‌های وضعیت پرونده را در چرخه‌اش جلو می‌برند: تازه، واگذارشده، در دست بررسی، ارجاع‌شده، حل‌شده، بسته‌شده و در صورت لزوم بازگشایی‌شده. فقط وضعیت‌های مجاز بعدی نمایش داده می‌شوند، پس اگر دکمه‌ای نیست یعنی

آن جابه‌جایی پذیرفته نمی‌شود. ارجاع به سطح بالاتر پرونده را یک سطح بالا می‌برد و افزودن یادداشت در سوابق پرونده می‌نویسد، که پس از ثبت قابل ویرایش نیست.

بخش سامانه مرجع نشان می‌دهد پرونده با سامانه تیکتینگ (مثلاً TheHive) همگام است یا نه. جمله «هیچ سامانه تیکتینگ پیکربندی نشده است» یک وضعیت عادی است، نه خطا.

محدودیت. از پنل پرونده نمی‌توان تصمیمی را تأیید یا رد کرد. مالکیت پرونده و تصمیم درباره اقدام عمداً از هم جدا نگه داشته شده‌اند، تا دسترسی به سامانه تیکتینگ به اختیار مهار یک میزبان تبدیل نشود.

اقدامات پیشنهادی هوش مصنوعی

3 اقدام

اقدامات پیشنهادی هوش مصنوعی

A1

Disable account

هدف: mmalek

Confirmed credential compromise

Locks the user out

94%

دلیل

اثر

اطمینان

برنامه سطح ۲ بالا را تأیید کنید تا اجرای خودکار انجام شود

A2

Isolate host

هدف: HR-WIN-11

SYSTEM-level compromise

Contains the endpoint

92%

دلیل

اثر

اطمینان

برنامه سطح ۲ بالا را تأیید کنید تا اجرای خودکار انجام شود

A3

Block IP

هدف: 45.9.148.117

Low-reputation egress peer

Stops egress

98%

دلیل

اثر

اطمینان

برنامه سطح ۲ بالا را تأیید کنید تا اجرای خودکار انجام شود

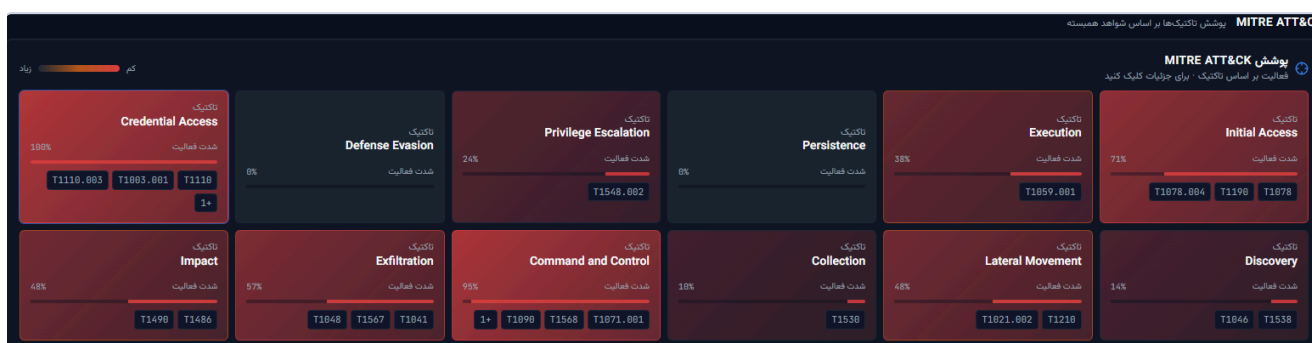
همان اقدام‌های برنامه، این بار با هدف، دلیل، اثر و اطمینان هرکدام. برای رخدادهای زنده این‌ها را یکی‌یکی اجرا نمی‌کنید؛ جمله «برنامه سطح ۲ بالا را تأیید کنید تا اجرای خودکار انجام شود» یعنی کار از پنل تصمیم پیش می‌رود.

۵/۳ تحلیل ریسک



پرریسک‌ترین کاربران، میزبان‌ها و نشانی‌هایی که وضعیت امنیتی کنونی را بالا برده‌اند. فهرست کامل و قابل جست‌وجو در صفحه ریسک موجودیت‌هاست (بخش ۱۰).

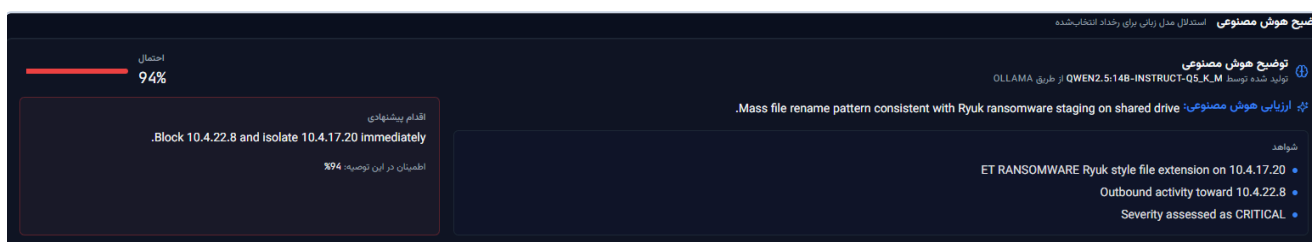
۵/۴ پوشش MITRE ATT&CK



فعالیت بر اساس تاکتیک ATT&CK؛ خانه‌های قرمزتر یعنی فعالیت بیشتر و شناسه تکنیک‌های دیده‌شده داخل هر خانه نوشته شده است. برای جزئیات روی خانه کلیک کنید.

تکنیک‌ها با فهرست محلی ATT&CK سنجیده می‌شوند. شناسه‌ای که در فهرست نباشد «فهرست‌نشده» علامت می‌خورد، چون آن فهرست زیرمجموعه است و نبودن یک شناسه در آن، دلیل ساختگی بودنش نیست.

۵/۵ توضیح هوش مصنوعی



استدلال مدل برای رخداد انتخاب‌شده: ارزیابی، شواهدی که به آن تکیه کرده، اقدام پیشنهادی و احتمال. نام مدلی هم که این متن را نوشته در پنل می‌آید، مثلاً `qwen2.5:14b-instruct` از طریق Ollama.

۵/۶ سلامت سامانه



خلاصه‌ای از صفحه سلامت سامانه (بخش ۱۱) که برای نگاه گذرا در همین صفحه گذاشته شده است.

۶. کار روی یک رخداد: تصمیم سطح ۲

این پنل قلب AO-SOC است. یکبار بررسی می‌کنید و پس از تأیید، ابزارهای پاسخ کل برنامه را خودشان اجرا می‌کنند.

تصمیم سطح ۲ هوش مصنوعی

یکبار بررسی کنید - SOAR کل برنامه را خودکار اجرا می‌کند

تپ: حکم هوش مصنوعی

در انتظار تأیید

CONTAIN

اطمینان: 93%

استدلال

Three unrelated tools independently observed stages of the same intrusion against one account and one host. No single alert justifies containment; the correlation does.

ریسک در صورت اجرا

Disabling mmalek locks an HR user out mid-shift and isolating .HR-WIN-11 drops any in-flight payroll session on that endpoint

4 برنامه اقدام یکپارچه (3)

PENDING

نوشتن پرخطر

Disable account

هدف: mmalek

Confirmed credential compromise

بازگردانی با: Enable account

بازگردانی پس از اجرای اقدام در دسترس می‌شود

PENDING

نوشتن پرخطر

Isolate host

هدف: HR-WIN-11

SYSTEM-level compromise

بازگردانی با: Release host from isolation

بازگردانی پس از اجرای اقدام در دسترس می‌شود

PENDING

نوشتن پرخطر

Block IP

هدف: 45.9.148.117

Low-reputation egress peer

بازگردانی با: Unblock IP

بازگردانی پس از اجرای اقدام در دسترس می‌شود

1 تأیید برنامه

3 ویرایش

2 رد

5 رد پای حساب

پنل از بالا به پایین این‌ها را می‌گوید:

- **حکم:** یکی از **CONTAIN** (مهارد)، **ESCALATE** (ارجاع به سطح بالاتر)، **INVESTIGATE** (بررسی بیشتر)، **MONITOR** (زیر نظر گرفتن) و **IGNORE** (اقدامی لازم نیست).
- **وضعیت:** در انتظار تأیید، تأیید شده، در حال اجرا، تکمیل. وضعیت‌های دیگری هم ممکن است ببینید: رد شده، ناموفق، اجرای آزمایشی و جایگزین‌شده.
- **منبع تصمیم:** نشان **حکم هوش مصنوعی** یعنی مدل تصمیم گرفته، **بازگشت به قاعده** یعنی مدل پاسخ قابل استفاده‌ای نداده و یک قاعده مبتنی بر شدت جای آن را گرفته، و **اصلاح تحلیل‌گر** یعنی انسانی آن را تغییر داده است. موارد «بازگشت به قاعده» را با دقت بیشتری بخوانید؛ هیچ استدلالی پشتشان نیست.
- **استدلال:** دلیل تصمیم به زبان ساده.
- **ریسک در صورت اجرا،** در کادر کهربایی: اینکه اجرای برنامه چه چیزی را ممکن است مختل کند. مثلاً غیرفعال‌شدن حساب یک کاربر در میانه شیفت.
- **برنامه اقدام یکپارچه (۴):** هر اقدام با هدف و دلیلش، رده خطر (فقط خواندن، نوشتن کم‌خطر، نوشتن پرخطر، مخرب)، وضعیت بازگشت‌پذیری (قابل بازگردانی با نام اقدام وارونه، بازگشت‌ناپذیر، یا چیزی برای بازگرداندن نیست) و در صورت لزوم نشان محافظ: دارایی حیاتی، حساب دارای دسترسی ویژه یا حساب سرویس.
- **دکمه‌ها:** تأیید برنامه (۱)، رد (۲) و ویرایش (۳).
- **ردپای حسابرسی (۵):** اینکه این تصمیم چگونه ساخته شده (بخش ۶/۴).

۶/۱ تأیید برنامه

۱. استدلال، پنل وضعیت امنیتی و کادر ریسک در صورت اجرا را بخوانید.
۲. هدف تک‌تک اقدام‌ها را بررسی کنید؛ میزبان، حساب یا نشانی درست است؟
۳. تأیید برنامه را بزنید.

اقدام‌ها در صف می‌روند و خودکار اجرا می‌شوند. وضعیت هر اقدام از **PENDING** به **EXECUTING** و بعد **DONE** می‌رود. وقتی همه موفق شدند، رخداد بسته می‌شود، از صف بیرون می‌رود و به بایگانی می‌رسد و یک نوار سبز این را اعلام می‌کند.

The screenshot displays the SOAR interface with two main alert panels. The top panel, titled 'Privilege escalation to SYSTEM (+2 related from 3 tools)', shows an alert for 'ET RANSOMWARE Ryuk style file extension' with a severity of 97 and a risk level of 94%. It includes a timeline of events and a 'Mass file rename pattern consistent with Ryuk ransomware staging on shared drive. Tier-2 verdict. ESCALATE for 10.4.17.20 → 10.4.22.8' message. The bottom panel, titled 'صف رخدادهای هوش مصنوعی', shows a similar alert for 'ET RANSOMWARE Ryuk style file extension' with a severity of 97 and a risk level of 94%. It also includes a timeline of events and a 'Mass file rename pattern consistent with Ryuk ransomware staging on shared drive. Tier-2 verdict. ESCALATE for 10.4.17.20 → 10.4.22.8' message.

از همان نوار می‌توانید **مشاهده بایگانی** را بزنید، یا با دکمه بستن در گوشه نوار آن را کنار بگذارید.

محدودیت مهم: اجرای آزمایشی. اگر استقرار با `RESPONSE_DRY_RUN=true` بالا آمده باشد، اقدام‌ها به‌جای «تکمیل»، وضعیت اجرای آزمایشی می‌گیرند و پیام می‌دهند که چیزی به هیچ مجری ارسال نشد. رخداد هم «مهار شده» علامت نمی‌خورد. این رفتار عمدی است، چون مهار شبیه‌سازی‌شده‌ای که مثل مهار واقعی به نظر برسد، خطرناک‌ترین چیزی است که این سامانه می‌تواند نشان بدهد.

۶٫۲ ویرایش برنامه

وقتی مدل تا حدی درست گفته، ویرایش بهتر از رد است: حکم اشتباه است، هدفی جابه‌جا شده، اقدامی اضافه است یا یکی کم است.



۱. ویرایش را بزنید.

۲. اگر لازم است حکم را عوض کنید.

۳. نام، هدف یا دلیل هر اقدام را تغییر دهید؛ افزودن اقدام سطر تازه می‌سازد و نماد سطل زباله سطر را برمی‌دارد.

۴. در کادر پایین بنویسید مدل چه چیزی را اشتباه دیده است؛ مثلاً «مجوز تغییر تأییدشده را ندید».

۵. **ذخیره اصلاح** را بزنید و بعد برنامه اصلاح شده را تأیید کنید.

اصلاح شما به عنوان برچسب ذخیره می شود و بعداً در سابقه ای می نشیند که تصمیم های آینده با آن سنجیده می شوند. تأیید و رد فقط ثبت می کنند که ماشین درست یا غلط گفته؛ ویرایش تنها جایی است که ثبت می شود پاسخ درست چه بود.

دو محدودیت را در ویرایش به خاطر بسپارید: برنامه ای که هرگز قابل اجرا نباشد پذیرفته نمی شود، مثل اقدام «مسدودسازی IP» با هدفی که نشانی IP نیست؛ و برنامه ای که اجرا شده دیگر ویرایش نمی شود، چون سند چیزی است که واقعاً فرستاده شده است.

تصمیم سطح ۲ هوش یکبار بررسی کنید - SOAR کل برنامه را خودکار اجرا می‌کند

CONTAIN ⓘ در انتظار تأیید ثبت حکم هوش مصنوعی

اطمینان: 93%

استدلال

Three unrelated tools independently observed stages of the same intrusion against one account and one host. No single alert justifies containment; the correlation does.

ریسک در صورت اجرا
Disabling mmalek locks an HR user out mid-shift and isolating HR-WIN-11 drops any in-flight payroll session on that endpoint

برنامه اقدام یکپارچه (3)

PENDING Disable account ⓘ نوشتن پرخطر
هدف: mmalek
Confirmed credential compromise
بازگردانی با: Enable account قابل بازگردانی
بازگردانی پس از اجرای اقدام در دسترس می‌شود

PENDING Isolate host ⓘ نوشتن پرخطر
هدف: HR-WIN-11
SYSTEM-level compromise
قابل بازگردانی
بازگردانی با: Release host from isolation بازگردانی پس از اجرای اقدام در دسترس می‌شود

PENDING Block IP ⓘ نوشتن پرخطر
هدف: 45.9.148.117
Low-reputation egress peer
قابل بازگردانی
بازگردانی با: Unblock IP بازگردانی پس از اجرای اقدام در دسترس می‌شود

یادداشت رد (اختیاری)

چرا این برنامه رد می‌شود؟

رد انصراف

ردپای حسابرسی

رد را بزنید، در صورت تمایل دلیلش را در یادداشت بنویسید و دوباره رد را بزنید تا قطعی شود. هیچ اقدامی اجرا نمی‌شود. رد برای وقتی است که هیچ کاری لازم نیست؛ مثلاً اسکنر مجاز سازمان یا یک مثبت کاذب شناخته‌شده.

تصمیم سطح ۲ هوش مصنوعی یکبار بررسی کنید - SOAR کل برنامه را خودکار اجرا می‌کند

اطمینان: 93%

استدلال

Three unrelated tools independently observed stages of the same intrusion against one account and one host. No single alert justifies containment; the correlation does.

ریسک در صورت اجرا

Disabling mmalek locks an HR user out mid-shift and isolating .HR-WIN-11 drops any in-flight payroll session on that endpoint

برنامه اقدام یکپارچه (3)

PENDING **Disable account**

هدف: mmalek

Confirmed credential compromise

بازگردانی قابل بازگردانی:

بازگردانی پس از اجرای اقدام در دسترس می‌شود

PENDING **Isolate host**

هدف: HR-WIN-11

SYSTEM-level compromise

بازگردانی قابل بازگردانی:

بازگردانی پس از اجرای اقدام در دسترس می‌شود

PENDING **Block IP**

هدف: 45.9.148.117

Low-reputation egress peer

بازگردانی قابل بازگردانی:

بازگردانی پس از اجرای اقدام در دسترس می‌شود

ردپای حسابرسی

خودگردانی پیشنهادی - هنوز کسی تأیید نکرده

مدل scripted • scripted

اجرا RUN-74F8C6D0AD5B

درهم استدلال 5a00aa68f264...5e82e3ca

درستی

اطمینان، گزارش خود مدل است و کالبره نیست - نمایش داده می‌شود و هرگز برای تصمیم‌گیری به کار نمی‌رود.

با کلیک روی ردپای حسابرسی این بخش باز می‌شود و می‌گویید تصمیم چطور ساخته شده است:

- **خودگردانی:** پیشنهادی (هنوز کسی تأیید نکرده)، زیر نظارت (انسانی تأیید کرده) یا خودکار (خلبان خودکار بر پایه سابقه تأیید کرده).

- **مدل و اجرا:** نام مدلی که تصمیم را نوشته و شناسه آن اجرا.
- **درهم استدلال** به همراه دکمه رونوشت، و **درستی:** «تأییدشده» یعنی پرسش و پاسخ ذخیره شده هنوز با درهم خود می خوانند و «ناهمخوان» یعنی رکورد دست کاری شده است.
- **دریافت JSON:** کل پرونده تصمیم شامل وضعیت، تصمیم، اقدام ها و ردپای حسابرسی، برای گزارش یا مستندسازی.

۶/۵ ثبت آنچه در عمل رخ داد

پس از قطعی شدن تصمیم، پنل می پرسد در عمل چه شد و تا ۷۲ ساعت (قابل تنظیم) منتظر پاسخ می ماند: **مثبت درست** یعنی حمله واقعی بود، **مثبت کاذب** یعنی نبود و **بازگشایی شده** یعنی دوباره برگشت. این پاسخ ها تزئینی نیستند. همین ها تعیین می کنند کدام منبع تشخیص و کدام نوع حکم آن قدر قابل اعتماد هست که روزی بدون انسان اجرا شود.

۶/۶ خلبان خودکار

اگر سازمان خلبان خودکار را فعال کرده باشد، بعضی تصمیم ها بدون کلیک اجرا می شوند. شرطش هم عدد اطمینان نیست: باید به اندازه کافی مورد مشابه در گذشته باشد که انسان ها با همان حکم تأییدشان کرده باشند، هیچ کدام بازگردانده نشده باشد و تازه ترین شان هم قدیمی نباشد. چهار چیز هرگز خودکار اجرا نمی شوند: اقدام روی دارایی حیاتی مثل کنترل کننده دامنه، غیرفعال کردن یا بازنشانی حساب دارای دسترسی ویژه و حساب سرویس، اقدام بازگشت ناپذیر، و اقدام مخرب. در بایگانی، رخدادی که خلبان خودکار بسته، به جای نشان **تحلیل گر** نشان **خلبان خودکار** دارد.

۷. هشدارهای زنده و راهنمای رخداد

98:32:07
۳۱ شهریور ۱۴۰۵ - کیبورد

FA EN

وضعیت
امنیتی

پایان (97)

پاسخ
خودکار

مدل
زبان

کارگزار خوش
مصنوعی

اسپلنک

سلامت
سامانه

ریسک
موجودیت‌ها

پایگانی

رخدادها

هشدارهای
زنده

مرکز
فرماندهی

AO-SOC
فرماندهی

گزارش هشدارهای زنده
هشدارهای دریافتی از اسپلنک توسط کارگزار Aegis-Link

هشدارهای زنده
13

در انتظار
9

مهار شده
4

بحرانی
2

بالا
5

متوسط / پایین
2

مهار شده

راهنمای رخداد
ALT-BE524263ADD8
تحلیل هوش مصنوعی
Mass file rename pattern consistent with Ryuk ransomware staging on shared drive
مهار پیشنهادی
توصیه اصلی
Block 10.4.22.8 and isolate 10.4.17.20 immediately

9 هشدار کارگزار

زمان	شدت	وضعیت	مبدأ	مقصد	امضا
21:01	بحرانی	فعال	10.4.17.20	10.4.22.8	...Ryuk style file extension
21:01	بحرانی	فعال	10.4.9.17	10.4.21.50	...ternalBlue SMB attempt
21:01	بالا	فعال	10.4.73.16	198.51.188.14	...SNI to DGA-like domain
21:01	بالا	فعال	10.4.59.14	8.8.8.8	...NS Query for .onion TLD
21:01	بالا	فعال	10.4.90.12	193.142.146.4	...nd to MSSQL port 1433
21:01	بالا	فعال	10.4.103.18	203.0.113.44	...ershell DownloadString
21:01	بالا	فعال	10.4.21.18	185.220.101.7	...ARE Known C2 Beacon
21:01	متوسط	فعال	10.4.38.15	177.185.83.40	...R SQL Injection Attempt
21:01	متوسط	فعال	10.4.45.11	45.155.205.211	...AN Potential SSH Scan

مرکز فرماندهی v2.8.8 AO-SOC

اسپلنک - کارگزار موفق مصنوعی - مدل محلی (Qwen) - پاسخ خودکار

این صفحه گزارش خام هشدارهای کارگزار است و برای مرور سریع ساخته شده. کاشی‌های بالا شمار هشدارهای زنده، در انتظار، مهارشده، بحرانی، بالا و متوسط یا پایین را می‌دهند و جدول پایین زمان، شدت، وضعیت، نشانی مبدأ و مقصد و امضای هر هشدار را.

با کلیک روی یک هشدار، راهنمای رخداد آن در کنار باز می‌شود.

88:32:09

۳۱ شهریور ۱۴۰۵ - گریبوری

FA EN

97

ایلا

وضعیت امنیتی

پاسخ خودکار

مدل زبانی

کارگزار هوش مصنوعی

اسپلنک

سلامت سامانه

ریسک موجودیت‌ها

پایگانی

رخدادها

هشدارهای زنده

مرکز فرماندهی

AO-SOC

مرکز فرماندهی

مرکز فرماندهی

گزارش هشدارهای زنده

Aegis-Link توسط کارگزار Aegis-Link

هشدارهای زنده

13

در انتظار

9

مهار شده

4

بحرانی

2

ایلا

5

متوسط / پایین

2

بروزرسانی

مهار جمعه

راهنمای رخداد

ALT-93C4062FE914

تحلیل هوش مصنوعی

SMB exploit traffic targeting file server – Immediate lateral movement risk

مهار پیشنهادی

Block egress to 10.4.21.50 at the perimeter firewall

Isolate host 10.4.9.17 from the network segment

Collect memory dump and triage for credential theft

توصیه اصلی

Block 10.4.21.50 and isolate 10.4.9.17 immediately

9 هشدار کارگزار

زمان

شدت

وضعیت

مبدأ

مقصد

امضا

21:01

بحرانی

فعال

10.4.17.20

10.4.22.8

...Ryuk style file extension

21:01

بحرانی

فعال

10.4.9.17

10.4.21.50

...ternalBlue SMB attempt

21:01

ایلا

فعال

10.4.73.16

198.51.100.14

...SNI to DGA-like domain

21:01

ایلا

فعال

10.4.59.14

8.8.8.8

...NS Query for .onion TLD

21:01

ایلا

فعال

10.4.90.12

193.142.146.4

...nd to MSSQL port 1433

21:01

ایلا

فعال

10.4.103.18

203.0.113.44

...erashell DownloadString

21:01

ایلا

فعال

10.4.21.10

185.220.101.7

...ARE Known C2 Beacon

21:01

متوسط

فعال

10.4.30.15

177.185.83.40

...R SQL Injection Attempt

21:01

متوسط

فعال

10.4.45.11

45.155.205.211

...AN Potential SSH Scan

مرکز فرماندهی AO-SOC - v2.8.8

اسپلنک - کارگزار هوش مصنوعی - مدل محلی (Qwen) - پاسخ خودکار

در این پنل خلاصه یک‌خطی تحلیل، فهرست مراحل مهار پیشنهادی (هر مرحله پس از انجام‌شدن سبز و تیک‌خورده می‌شود) و مهم‌ترین گام زیر عنوان **توصیه اصلی** می‌آید. دکمه **مهار حمله** هم همان کار بخش ۵/۲ را می‌کند.

برای تأیید و اجرای واقعی برنامه، رخداد را در مرکز فرماندهی یا در صفحه جزئیاتش باز کنید و از **تأیید برنامه** استفاده کنید (بخش ۶).

۸. فهرست رخدادها و صفحه جزئیات

08:32:11
31 شهریور 1405 - گریبونج

FA

EN

پاسخ خودکار

مدل زبانی

کارگزار هوش مصنوعی

اسپلنک

پار سلامت سامانه

ریسک موجودیت‌ها

پارکشت

رخدادها

9 هشدارهای زنده

مرکز فرماندهی

AO-SOC
مرکز فرماندهی

رخدادها

همه رخدادهای همبسته در محیط

صف رخدادها	شدت	وضعیت	عنوان	ریسک	اطمینان	باز کردن
13 مورد						
بازرسی تازه	فعال	ALT-BE524263A0D8ET RANSOMWARE Ryuk style file extension	97	94%	←	
بازرسی تازه	فعال	ALT-93C4B62FE914ET EXPLOIT Possible EternalBlue SMB attempt	97	94%	←	
بازرسی نمایشی	فعال	INC-2B43Possible Ransomware Activity on FIN-WIN-04	97	94%	←	
بالا تازه	فعال	ALT-A67AAB651D86ET INFO Suspicious TLS SNI to DGA-like domain	78	88%	←	
بالا تازه	فعال	ALT-C1D352574123ET DNS Query for .onion TLD	78	88%	←	
بالا تازه	فعال	ALT-B63124A4FD55ET POLICY Suspicious inbound to MSSQL port 1433	78	88%	←	
بالا تازه	فعال	ALT-FC7173C73670ET POLICY Powershell DownloadString	78	88%	←	
بالا تازه	فعال	ALT-1AC3F5974898ET MALWARE Known C2 Beacon	78	88%	←	
بالا نمایشی	در حال بررسی	INC-2B44Brute Force Campaign against VPN Gateway	78	88%	←	
متوسط تازه	فعال	ALT-392B0957346CET WEB_SERVER SQL Injection Attempt	62	71%	←	
متوسط تازه	فعال	ALT-BC126E54C699ET SCAN Potential SSH Scan	62	71%	←	
متوسط نمایشی	باز	INC-2B39Suspicious Cloud IAM Role Assumption	62	71%	←	
پایین نمایشی	تحت نظارت	INC-2B38Outdated TLS Handshake on External Endpoint	31	64%	←	

اسپلنک - کارگزار هوش مصنوعی - مدل محلی (Qwen) - پاسخ خودکار

مرکز فرماندهی AO-SOC - v2.8.8

صفحه رخدادها همه رخدادهای فعال را در یک جدول می‌آورد: شدت، وضعیت با نشان زنده یا نمایشی، عنوان، ریسک، اطمینان مدل و ستون باز کردن. با کلیک روی هر سطر، صفحه جزئیات همان رخداد باز می‌شود.

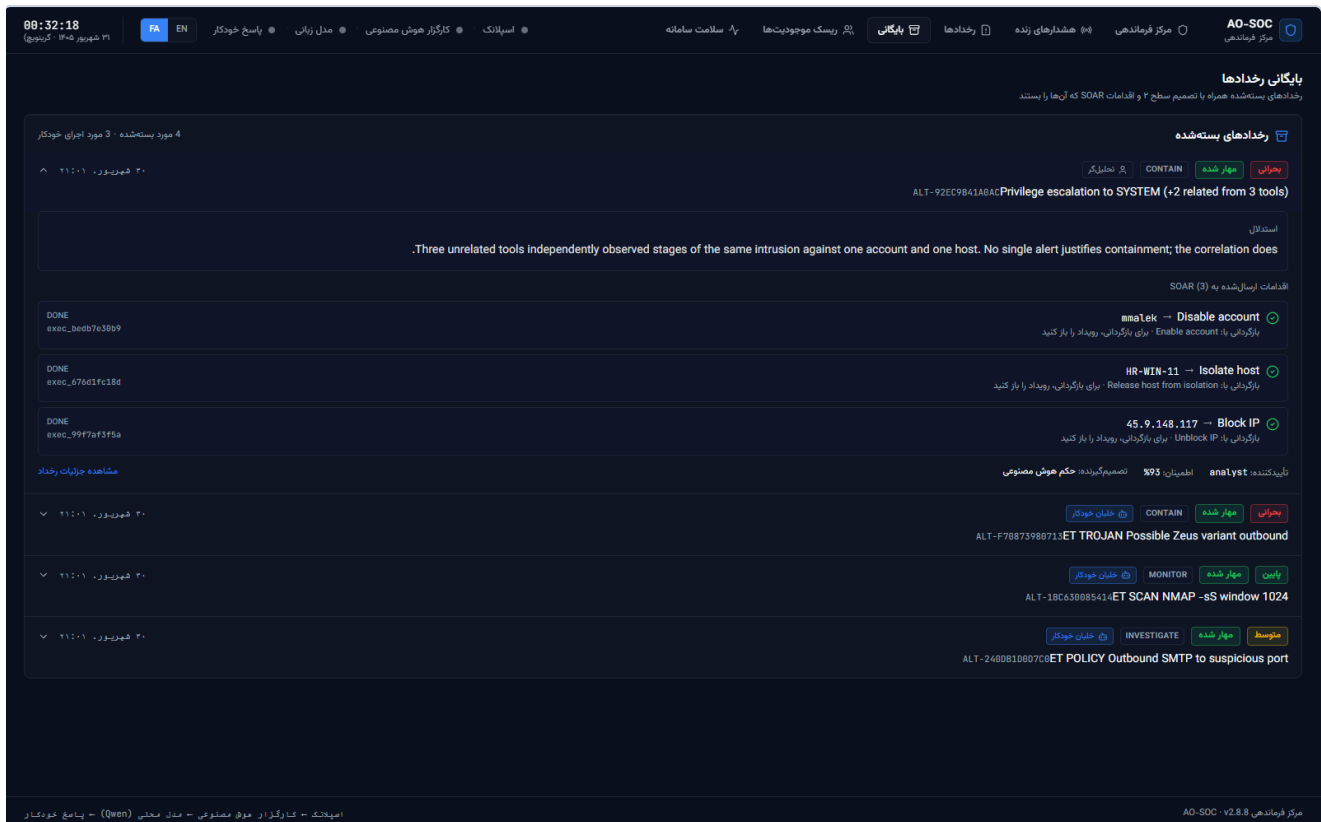
08:32:14 (۳۱ شهریور ۱۴۰۵ - گریبونج)	FA EN	پاسخ خودکار	مدل زبانی	کارگزار هوش مصنوعی	اسپلنک	سلامت سامانه	ریسک موجودیت‌ها	پارگشت	رخدادها	۹ هشدارهای زنده	مرکز فرماندهی	AO-SOC مرکز فرماندهی
پارگشت به مرکز فرماندهی ALT-BE524263A0D8												
ET RANSOMWARE Ryuk style file extension												
ستاریوی جمله												
T1486 IDS Alert 88:48 ET RANSOMWARE Ryuk style file extension triggered												
T1486 Follow-on 88:48 Sustained session 10.4.17.20 → 10.4.22.8												
وضعیت امنیتی												
1 تشخیص، همبسته‌شده از 1 ابزار												
SPLUNK												
امتیاز ریسک همبستگی												
45+ بیشترین شدت میان 1 تشخیصی برابر MEDIUM است												
همبسته بر اساس												
10.4.22.8 → 10.4.17.28												
تشخیص‌های عضو												
04:10 متوسط SPLUNK												
ET RANSOMWARE Ryuk style file extension												
راستی‌آزمایی و سابقه												
چه چیزی در برابر یک مرجع بررسی شد و این مرکز عملیات پیش‌تر چه تصمیمی گرفته است												
هیچ شانه‌ای از این وضعیت در فید local یافت نشد.												
2 مورد بررسی شد (نشان‌های داخلی و هوش‌ها هرگز به فید فرستاده نمی‌شوند)												
سابقه												
سابقه به‌اندازه مشابهی وجود ندارد - این تصمیم به‌اقتضای طراحی منتظر تحلیل‌گر می‌ماند.												
پرونده												
چه کسی روی آن کار می‌کند و در چه وضعیتی است												
P1 تازه CASE-99340EB83A												
تصمیم سطح ۲ هوش مصنوعی												
یکبار بررسی کنید - SOAR کل برنامه را خودکار اجرا می‌کند												
اطمینان: 95%												
در انتظار تأیید												
ESCALATE												
استدلال												
Mass file rename pattern consistent with Ryuk ransomware staging on .shared drive. Tier-2 verdict ESCALATE for 10.4.17.20 → 10.4.22.8												
ریسک در صورت اجرا												
Pulls the IR team in out of hours and pauses Tier-2 handling												
برنامه اقدام بک‌آپ‌رچه (3)												
PENDING												
Block IP												
هدف: 10.4.22.8												
Malicious or suspicious peer												
Unblock IP												
پارگشتی یا: پارگشتی پس از اجرای اقدام در دسترس می‌شود												
PENDING												
Isolate Host												
هدف: 10.4.17.28												
Active malicious activity												
Release host from isolation												
پارگشتی یا: پارگشتی پس از اجرای اقدام در دسترس می‌شود												
PENDING												
Investigate												
هدف: 10.4.17.28												
Memory triage for credential theft												
تأیید برنامه												
ویرایش												
رد												
ردیای حساسیت												

صفحه جزئیات همان پنل‌های مرکز فرماندهی را برای یک رخداد کنار هم می‌گذارد: در ستون راست سناریوی حمله، وضعیت امنیتی، راستی‌آزمایی و سابقه، پرونده و توضیح هوش مصنوعی؛ و در ستون چپ تصمیم سطح ۲ با همه دکمه‌هایش، دارایی‌های متأثر، تکنیک‌های MITRE و اقدامات پیشنهادی.

دو وقت سراغ این صفحه می‌روید: وقتی می‌خواهید نشانی یک رخداد را برای کسی بفرستید، و وقتی رخدادی بسته شده و باید اقدامی را روی آن بازگردانید (بخش ۹/۲).

۹. بایگانی و بازگردانی اقدام‌ها

۹/۱ بایگانی



رخدادهای بسته‌شده از تازه‌ترین به قدیمی‌ترین اینجا می‌آیند. سرصفحه می‌گوید چند رخداد بسته شده و چند تا از آن‌ها بدون دخالت انسان اجرا شده‌اند. هر سطر شدت، وضعیت مهارشده، حکم و تأییدکننده را نشان می‌دهد؛ نشان تحلیل‌گر یا خلبان خودکار.

با باز کردن هر سطر، استدلال تصمیم، همهٔ اقدام‌های ارسال‌شده به SOAR با وضعیت و شناسهٔ اجرا، نام تأییدکننده، اطمینان و منبع تصمیم دیده می‌شود. پیوند **مشاهده جزئیات رخداد** هم صفحهٔ کامل رخداد را باز می‌کند.

۹/۲ بازگردانی یک اقدام

هر اقدامی که نشان قابل بازگردانی دارد، پس از اجرا قابل پس‌گرفتن است؛ مثلاً مسدودسازی یک نشانی با رفع مسدودی همان نشانی وارونه می‌شود.

۱. از بایگانی **مشاهده جزئیات رخداد** را باز کنید. اگر رخداد هنوز فعال است، از مرکز فرماندهی هم می‌شود.
۲. در پنل تصمیم سطح ۲ اقدام موردنظر را پیدا کنید و **بازگردانی** را بزنید.

تصمیم سطح ۲ هوش مصنوعی یکبار بررسی کنید - SOAR کل برنامه را خودکار اجرا می‌کند

اطمینان: 93%

تکمیل

CONTAIN

استدلال

Three unrelated tools independently observed stages of the same intrusion against one account and one host. No single alert justifies containment; the correlation does.

ریسک در صورت اجرا

Disabling mmalek locks an HR user out mid-shift and isolating HR-WIN-11 drops any in-flight payroll session on that endpoint.

برنامه اقدام یکپارچه (3)

DONE

Disable account

نوشتن پرخطر

هدف: mmalek

Confirmed credential compromise

از طریق soar

exec_bedb7e38b9

بازگردانی قابل بازگردانی

بازگردانی

1

DONE

Isolate host

نوشتن پرخطر

هدف: HR-WIN-11

SYSTEM-level compromise

از طریق soar

exec_676d1fc18d

بازگردانی قابل بازگردانی

بازگردانی

DONE

Block IP

نوشتن پرخطر

هدف: 45.9.148.117

Low-reputation egress peer

از طریق soar

exec_99f7af3f5a

بازگردانی قابل بازگردانی

بازگردانی

اجرای SOAR تکمیل شد - رخداد مهار شد

در عمل چه شد

تا 72 ساعت پس از قطعی شدن تصمیم قابل ثبت است.

بازگشایی شده

مثبت کاذب

مثبت درست

رد پای حساسیتی

۳. اگر دلیلی دارید بنویسید؛ مثلاً «پنجره تغییر CHG-2211 این ترافیک را تأیید کرده بود».
۴. برای قطعی شدن، دوباره بازگردانی را بزنید.

تصمیم سطح ۲ هوش مصنوعی یکبار بررسی کنید - SOAR کل برنامه را خودکار اجرا می‌کند

اطمینان: 93%

تکمیل

CONTAIN

استدلال

Three unrelated tools independently observed stages of the same intrusion against one account and one host. No single alert justifies containment; the correlation does.

ریسک در صورت اجرا

Disabling mmalek locks an HR user out mid-shift and isolating HR-WIN-11 drops any in-flight payroll session on that endpoint.

برنامه اقدام یکپارچه (3)

DONE

نوشتن پرخطر

Disable account

هدف: mmalek

Confirmed credential compromise

از طریق soar

exec_bedb7e30b9

پارگردانی یا: Enable account

قابل بازگردانی

این اقدام پس گرفته شود؟

مثلاً: پنجره تغییر CHG-2211 این ترافیک را تأیید کرده بود.

بازگردانی

انصراف

DONE

نوشتن پرخطر

Isolate host

هدف: HR-WIN-11

SYSTEM-level compromise

از طریق soar

exec_676d1fc18d

پارگردانی یا: Release host from isolation

قابل بازگردانی

بازگردانی

DONE

نوشتن پرخطر

Block IP

هدف: 45.9.148.117

Low-reputation egress peer

از طریق soar

exec_99f7af3f5a

پارگردانی یا: Unblock IP

قابل بازگردانی

بازگردانی

اجرای SOAR تکمیل شد - رخداد مهار شد

در عمل چه شد

تا 72 ساعت پس از قطعی شدن تصمیم قابل ثبت است.

بازگشایی شده

مثبت کاذب

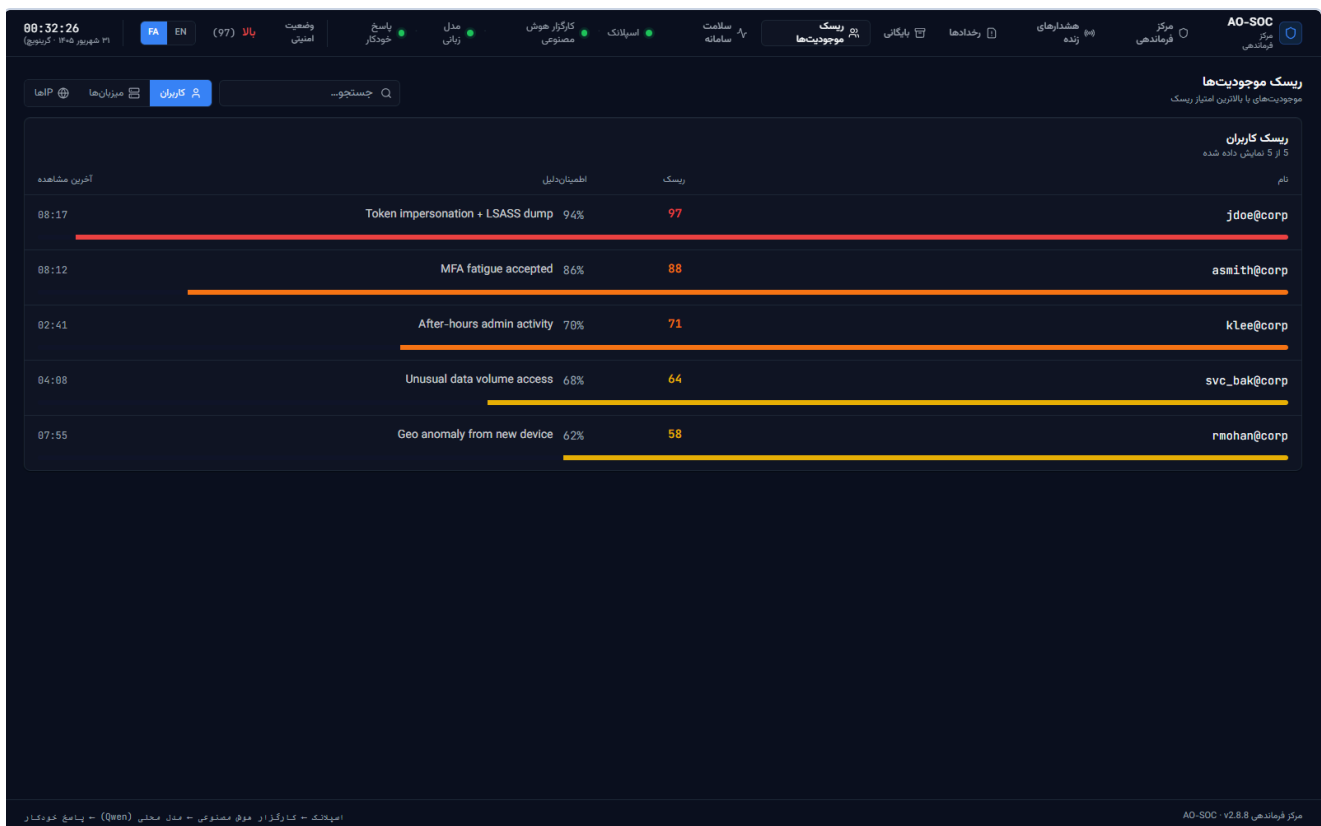
مثبت درست

ردیای حسابرسي

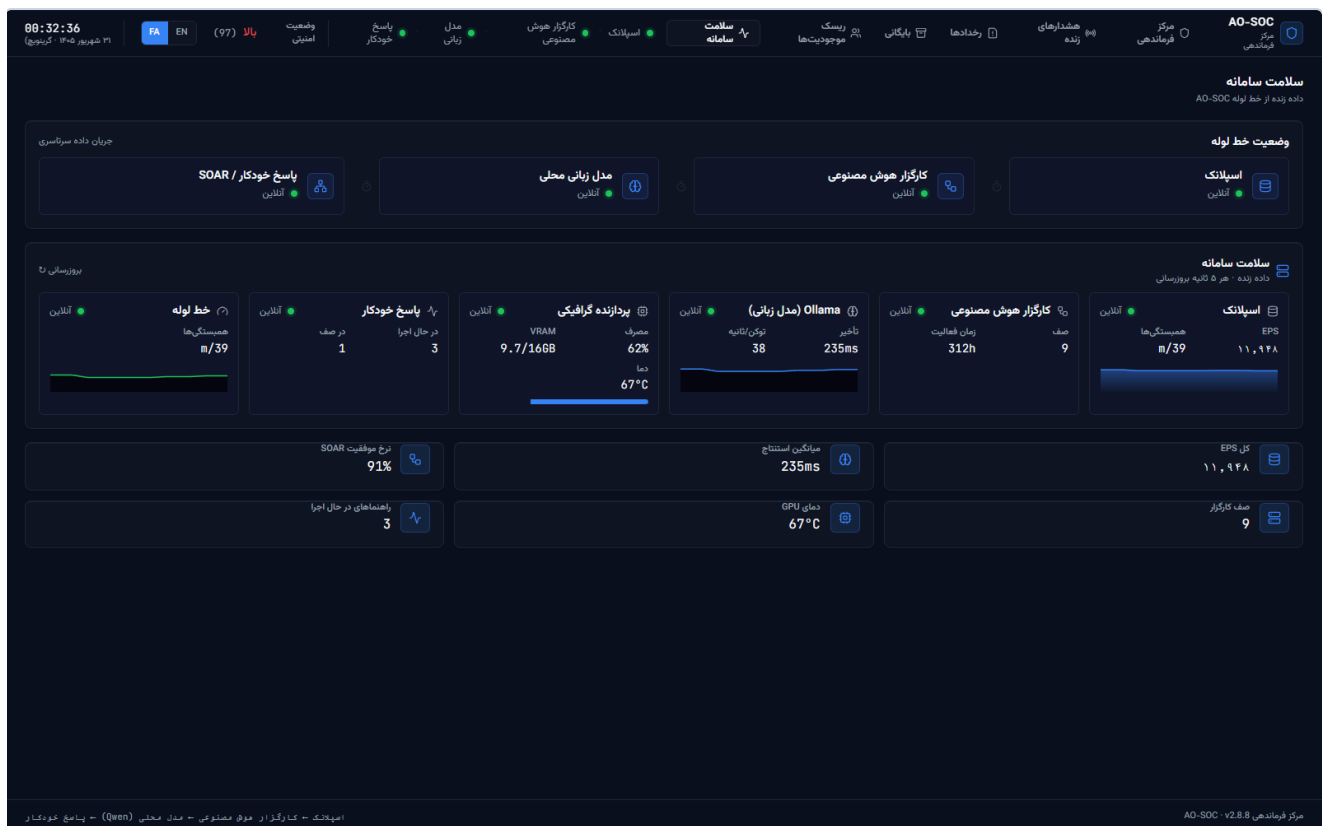
اقدام وارونه از همان مسیر اقدام اصلی فرستاده می‌شود. بعد از آن، اقدام نشان می‌دهد که چه کسی آن را بازگردانده و رخداد به جای ماندن در حالت «مهار شده» بازگشایی می‌شود. سوابق پرونده هم ثبت می‌کند چه چیزی اجرا شد و چه کسی آن را برگرداند.

سه نکته درباره بازگردانی: دکمه آن تنها پس از اجرای واقعی اقدام ظاهر می‌شود؛ اقدامی که نشان بازگشت‌ناپذیر دارد اصلاً چنین دکمه‌ای ندارد؛ و پیام «مجری بازگردانی را نپذیرفت» یعنی برای آن ابزار فرمان وارونه‌ای تعریف نشده و باید در خود آن ابزار کار را برگردانید.

۱۰. ریسک موجودیت‌ها



این صفحه به یک پرسش جواب می‌دهد: همین حالا کدام حساب یا میزبان بیشترین ریسک را دارد. با زبانه‌های بالا میان کاربران، میزبان‌ها و IP‌ها جابه‌جا می‌شوید و کادر جستجو فهرست را هم‌زمان با تایپ فیلتر می‌کند. هر سطر نام، امتیاز ریسک با نوار رنگی، اطمینان مدل، دلیل و زمان آخرین مشاهده را نشان می‌دهد. هنگام کار روی یک رخداد هم به کار می‌آید: پیش از تأیید اقدامی روی یک حساب، ببینید همان حساب سابقه‌ای دارد یا نه.

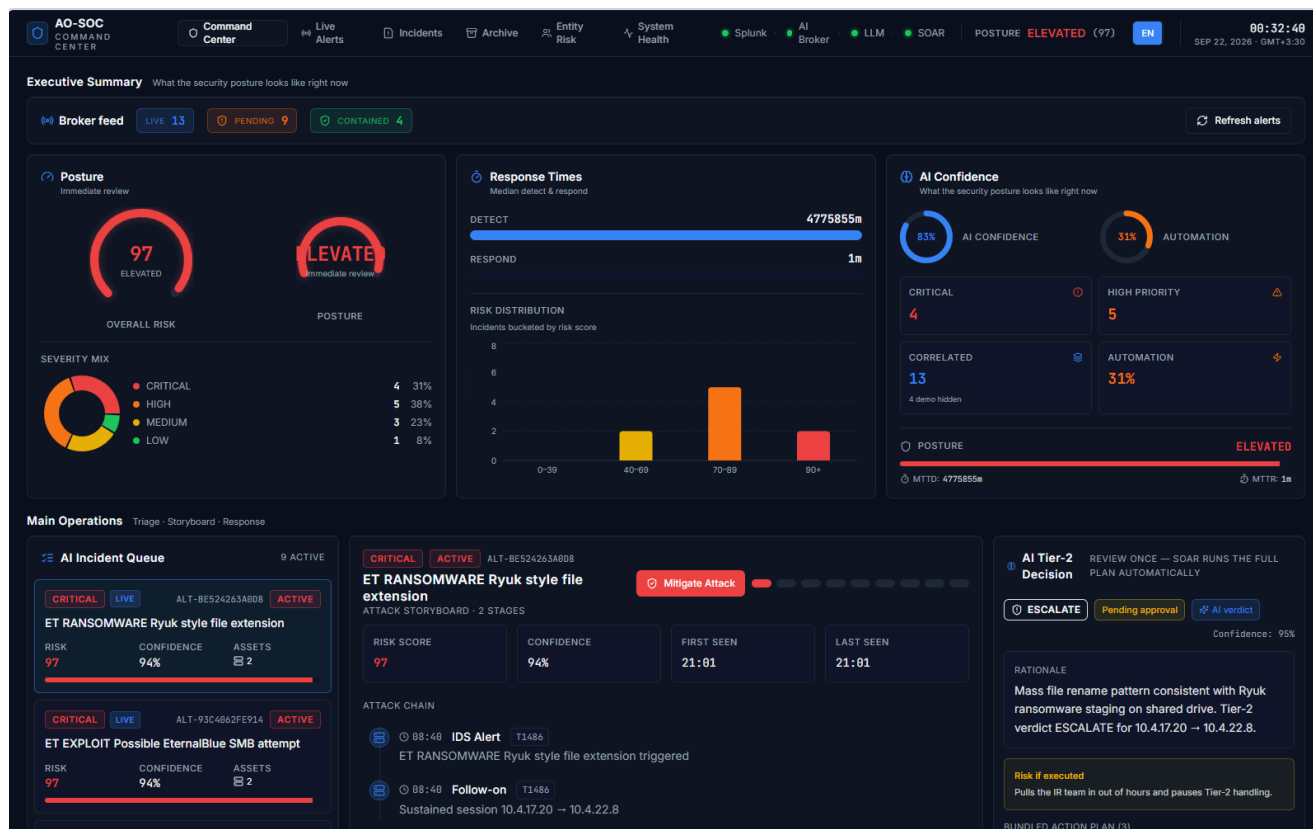


نوار وضعیت خط لوله چهار جزء را به ترتیب مسیر داده نشان می‌دهد: اسپلنک، کارگزار هوش مصنوعی، مدل زبانی محلی و پاسخ خودکار؛ هرکدام آنلاین، تضعیف‌شده، آفلاین یا نامشخص.

پایین‌تر، داده زنده هر ۵ ثانیه به‌روز می‌شود: رویداد در ثانیه و همبستگی‌ها از اسپلنک، طول صف و زمان فعالیت کارگزار، تأخیر و توکن بر ثانیه مدل، مصرف و VRAM و دمای پردازنده گرافیکی، و شمار اقدام‌های در حال اجرا و در صف. کاشی‌های پایین صفحه هم همین اعداد را به شکل خلاصه می‌دهند.

اگر جزئی قرمز یا خاکستری ماند، سراغ بخش ۱۵ بروید.

با EN در نوار بالا رابط انگلیسی می‌شود و با FA دوباره فارسی. در رابط فارسی، چیدمان راست‌به‌چپ است و برچسب‌ها، تاریخ‌ها و توضیح عامل‌های ریسک هم فارسی‌اند. انتخاب زبان در همان مرورگر به خاطر می‌ماند.



آغاز شیفت. با کلید شخصی خودتان وارد شوید. به چهار نقطه نوار بالا نگاه کنید؛ اگر همه سبز نیستند، اول سراغ صفحه سلامت سامانه بروید. بعد خلاصه مدیریتی را بخوانید تا بدانید وضعیت امنیتی کجاست، چند رخداد منتظر تصمیم مانده و ترکیب شدت‌ها چیست.

در طول شیفت، برای هر رخداد از بالای صف:

۱. رخداد را انتخاب کنید.

۲. اول سناریوی حمله، بعد وضعیت امنیتی (اینکه چه چیزی این تشخیص‌ها را به هم وصل کرده) و بعد راستی‌آزمایی و سابقه را بخوانید.

۳. در پنل پرونده رخداد را به خودتان واگذار کنید و وضعیتش را «در دست بررسی» بگذارید. کاری که مالک ندارد، کاری است که زمین می‌ماند.

۴. تصمیم بگیرید: برنامه درست است، تأیید کنید؛ تا حدی اشتباه است، ویرایش و بعد تأیید کنید؛ هیچ اقدامی لازم نیست، با یادداشت رد کنید؛ از سطح شما بالاتر است، پرونده را ارجاع دهید.

۵. هرچه به درد شیفت بعد می‌خورد در سوابق پرونده بنویسید.

۶. بعد از بسته‌شدن رخداد، مدخل آن را در بایگانی ببینید.

پایان شیفت. برای تصمیم‌هایی که امروز قطعی شده‌اند نتیجه را ثبت کنید (مثبت درست، مثبت کاذب یا بازگشایی‌شده). پرونده‌های نیمه‌کاره را با یک یادداشت به نفر بعد واگذار کنید و در آخر زبانه مرورگر را ببندید تا نشستتان بسته شود.

کار هفتگی سرپرست شیفت. یک نسخه پشتیبان بگیرید و همان نسخه را بازیابی کنید تا از سالم‌بودنش مطمئن شوید (بخش ۷ برنامه راه‌اندازی)، و بررسی کنید کدام منبع تشخیص بیشترین مثبت کاذب را تولید کرده است.

۱۴. واژه‌نامهٔ نشان‌ها و وضعیت‌ها

رنگ شدت: بحرانی قرمز، بالا نارنجی، متوسط زرد، پایین سبز. وضعیت امنیتی از بهترین به بدترین: پایین، محافظت‌شده، افزایش‌یافته، بالا.

اصطلاح	معنی
زنده / نمایشی	دادهٔ واقعی کارگزار در برابر دادهٔ نمونهٔ داخلی
وضعیت امنیتی (Situation)	یک یا چند تشخیص، احتمالاً از چند ابزار، دربارهٔ موجودیت‌های یکسان در یک بازهٔ زمانی
تصمیم سطح ۲	حکم: CONTAIN مهار کن، ESCALATE سطح بالاتر را درگیر کن، INVESTIGATE عمیق‌تر بررسی کن، MONITOR زیر نظر بگیر، IGNORE اقدامی لازم نیست
برنامه اقدام یکپارچه	مجموعه اقدام‌های پیوسته به یک تصمیم که با هم تأیید و اجرا می‌شوند
حکم هوش مصنوعی / بازگشت به قاعده / اصلاح تحلیل‌گر	اینکه تصمیم را مدل، قاعدهٔ شدت یا یک انسان گرفته است
فقط خواندن / نوشتن کم‌خطر / نوشتن پرخطر / مخرب	میزان تغییری که اقدام ایجاد می‌کند. اقدام مخرب اجرا نمی‌شود مگر سازمان آن را با تصمیم صریح فعال کرده باشد
قابل بازگردانی / بازگشت‌ناپذیر / چیزی برای بازگرداندن نیست	اینکه اقدام پس گرفته می‌شود یا نه
دارایی حیاتی / حساب دارای دسترسی ویژه / حساب سرویس	هدف‌هایی که خلبان خودکار به آن‌ها دست نمی‌زند
در انتظار تأیید ← تأیید شده ← در حال اجرا ← تکمیل	زنجیرهٔ عادی وضعیت یک برنامه
ناموفق	ابزار پاسخ درخواست را گرفت و نپذیرفت؛ دلیلش در رسید هست
مسدود	اقدام اصلاً از AO-SOC بیرون نرفت؛ یا هدف نامعتبر بود یا هیچ رابطی آن را انجام نمی‌دهد
اجرای آزمایشی	فقط شبیه‌سازی؛ چیزی به هیچ ابزاری فرستاده نشد
جایگزین‌شده	وضعیت در وضعیت دیگری ادغام شده و تصمیم جاری آنجاست
سابقه	موارد مشابه پیشین که انسان‌ها درباره‌شان تصمیم گرفته‌اند و خلبان خودکار به آن‌ها تکیه می‌کند
وضعیت‌های پرونده	تازه، واگذارشده، در دست بررسی، ارجاع‌شده، حل‌شده، بسته‌شده، بازگشایی‌شده
MTTD / MTTR	میانگین زمان شناسایی و میانگین زمان پاسخ

۱۵. وقتی چیزی درست کار نمی‌کند

نشانه	اولین جایی که باید نگاه کنید
صفحه ورود مدام برمی‌گردد	کلید نادرست یا باطل است، یا کلید کارگزار را به جای کلید داشبورد وارد کرده‌اید. از مدیر سامانه کلیدی از <code>AOSOC_API_KEYS</code> بگیرید
پیام «بارگذاری داشبورد ناموفق بود» با اشاره به درگاه ۴۳۱۷	API رابط کاربری بالا نیست. در حالت نمایشی <code>start-demo</code> را دوباره اجرا کنید؛ در Docker با <code>docker compose -f deploy/docker-compose.yml ps</code> وضعیت سرویس‌ها را ببینید
صف خالی است	ببینید ابزارهای تشخیص با کلید <code>ingest</code> به کارگزار می‌فرستند یا نه. در حالت نمایشی، در ویندوز <code>orchestrator\trigger-alert.ps1</code> یک هشدار تکی می‌سازد
رخدادهای تازه تصمیم نمی‌گیرند	احتمالاً صف تحلیل کار ناموفق دارد. از مدیر سامانه بخواهید <code>GET /api/queue</code> را ببیند. تشخیص‌ها در هر حال ذخیره شده‌اند و دوباره فرستادن لازم نیست
همه تصمیم‌ها «بازگشت به قاعده» هستند	مدل پاسخ نمی‌دهد. نقطه مدل زبانی در نوار بالا و صفحه سلامت سامانه را ببینید و مطمئن شوید Ollama اجراست و مدل دانلود شده است
اقدامی «ناموفق» شد	ابزار پاسخ آن را نپذیرفته است؛ دلیل در رسید تحویل نوشته شده. مشکل را در همان ابزار حل کنید یا برنامه را ویرایش کنید
اقدامی «مسدود» شد	هدف برای آن اقدام معتبر نیست یا هیچ رابطی آن را اجرا نمی‌کند. برنامه را ویرایش و هدف را اصلاح کنید
همه چیز «اجرای آزمایشی» است	استقرار هنوز در حالت آزمایشی است (<code>RESPONSE_DRY_RUN=true</code>). تا مرحله دوم برنامه راه‌اندازی، این همان رفتار درست است
وضعیت پرونده جابه‌جا نمی‌شود	آن جابه‌جایی مجاز نیست؛ فقط دکمه‌هایی که می‌بینید وضعیت‌های بعدی ممکن‌اند
نقطه‌های خط لوله خاکستری مانده‌اند	بررسی سلامت هنوز پاسخ نداده است. ۵ ثانیه صبر کنید یا صفحه را تازه کنید؛ اگر ماند، اجرای کارگزار را بررسی کنید

هنگام گزارش اشکال سه چیز را همراه کنید: شماره نسخه از پانویس صفحه، شناسه رخداد (مثل `ALT-8AE6D52F8208`) و در صورت امکان فایل JSON که از ردپای حسابرسی دریافت می‌شود.

تاریخچه تغییرات

نویسنده	تغییر	تاریخ	نسخه
J.Ekrami, Claude (Opus 5)	بازنویسی کامل متن فارسی بر پایه راهنمای نگارش فارسی: لحن رسمی روان به جای ترجمه واژه‌به‌واژه، جدا کردن «نکته» و «هشدار» و «محدودیت» و قرار دادنشان کنار همان مرحله‌ای که به آن مربوطاند، یکدست‌شدن زاویه دید (توضیح غیرشخصی، دستور دوم‌شخص)، نیم‌فاصله و اعداد فارسی و گیومه در سراسر متن. محتوا و تصویرها همان نسخه ۱/۱ است	تابستان ۱۴۰۵	۲/۰
J.Ekrami, Claude (Opus 5)	اصلاح تصویر پزل «وضعیت امنیتی» در بخش ۵/۲؛ تصویر نسخه ۱/۰ کارت وضعیت کلی را نشان می‌داد، چون هر دو یک عنوان دارند	تابستان ۱۴۰۵	۱/۱
J.Ekrami, Claude (Opus 5)	ویرایش نخست برای ao-soc نسخه ۲/۸/۹: نصب، ورود، همه منوها و صفحه‌ها، روند تصمیم سطح ۲، راهنمای رخداد، روال روزانه، واژه‌نامه و رفع اشکال با ۳۰ تصویر از رابط فارسی	تابستان ۱۴۰۵	۱/۰